

The HmrcRestClient and The Anti-Fraud Headers.

Date 12/02/21

Author : Ian H.

Version 1.0

Introduction

This is a set of REST headers to be passed in each call to the API, in an attempt to individually identify each user of the system and each call source. The idea was proposed at the start of 2019, with provisional header descriptions. They became compulsory in the middle of 2020 for some APIs and were updated at the end of 2020.

At the time of writing, they are compulsory for VAT, Income Tax and Self Assessment, being covered by the Version 3.0 specification (06/01/21). Information here was believed to be accurate at the time of writing, but the fraud headers have been subject to change and probably will continue to be so. The application developers should ensure that they check the current state of the headers, when coding their processes.

The Headers

There are either 6 or 8 defined header types, depending on whether you consider the “Other” types to be counted as defined. The listing below is copied directly from the “What you need to send” page on the HMRC website, February 2021 (obviously their copyright):

[Desktop application direct](#)

Your application is installed on a desktop connecting directly to HMRC. Desktops include computers and laptops.

[Desktop application via server](#)

Your application is installed on a desktop connecting to HMRC through intermediary servers. Desktops include computers and laptops.

[Web application via server](#)

Your application is web based, connecting to HMRC through intermediary servers.

[Mobile application direct](#)

Your application is installed on a mobile device connecting directly to HMRC. Mobile devices include phones and tablets.

[Mobile application via server](#)

Your application is installed on a mobile device connecting to HMRC through intermediary servers. Mobile devices include phones and tablets.

[Batch process direct](#)

Only select this for requests when your users do not initiate an action and your application uses batch processes, connecting directly to HMRC.

If your architecture is not listed

You can select other direct or other via server. We may ask you for more details.

[Other direct](#)

Your application connects directly to HMRC but is not covered by the common architectures.

Other via server

Your application connects to HMRC through intermediary servers but is not covered by the common architectures.

...and the remainder of that page...

Connecting to HMRC

If your application connects directly to HMRC, select a direct connection method.

If your application does not connect directly to HMRC, select a server connection method. Only consider intermediary servers that are part of your application domain and are in your control. Do not include third-party servers such as transport layers or internet providers.

Where multiple services manage your intermediary servers, headers must contain data from all services.

Originating device

Originating device means the device that initiates an action, for example a VAT return. In most connection methods, it is usually the physical device a person uses to initiate a request.

In desktop application direct, or desktop application via server, the originating device might be a hosted desktop environment accessed remotely by the user.

If actions initiated by users are stored on a server and sent in batches, the originating device is the user's device and not the server. You must only select batch process direct as a connection method when your users do not initiate an action.

(end of HMRC page)

Each of the header types links to another page, which specifies the details of the headers for that type. The UKDG MTD components and helper processes have only dealt with the first case, Desktop Application Direct. The elements required for that (V3.0 Jan 2021) are listed below and details are available on the HMRC website by following the link. The reader is strongly advised to study the relevant page in detail.

Gov-Client-Connection-Method

Gov-Client-Connection-Method: DESKTOP_APP_DIRECT Obviously this is a fixed value and can be hard-coded.

Gov-Client-Device-ID

This was originally described as the computer name, but for v3.0 this must be a UUID (GUID). Basically the application installer should now generate an installation GUID that is unique to that app on that machine. The developer has to provide or find a mechanism for accessing this.

Gov-Client-Local-IPs

This is described as a list of all Ipv4 and Ipv6 addresses available to the originating computer, which should be generated at the time the request is sent. Ipv6 values should be percent encoded.

Gov-Client-Local_IPs-Timestamp

The timestamp for when the IP list was generated. It is supposed to be UTC based and requires the format – YYYY-MM-DDTHH:NN:SS.000Z – which is a bit weird, but fortunately there is a method available for this : DateToISO8601 (in DateUtils) and can be called with DateToISO8601(Now, true);

Gov-Client-MAC-Addresses

A list of MAC addresses available on the machine. To be percent encoded.

Gov-Client-Multi-Factor

This should contain detail of how the user is validated when logging on to the application making the REST calls. There appears to be an assumption that all such apps will use multi-factor authentication and the normal user/password format does not comply. In this case you are supposed to set the type to “OTHER”, leave the values blank and notify HMRC, where the person you speak to may not have a clue what you are talking about. In order to pass the header validation tests in the sandbox, the demo apps set dummy values, which are obviously wrong, but keep the test API happy. The developer has to provide or find a mechanism for accessing these values if available.

Gov-Client-Screens

This is supposed to be information about the screens on the machine being used.

Gov-Client-Timezone

In the format UTC±<hh> : <mm>

Gov-Client-User-Agent

This has a new format now and requires OS family, OS version, device manufacturer and device model.

Gov-Client-User-IDs

A list of key-value pairs which should include the user name when logging on to the machine and the user name when logging on to the application.

Gov-Client-Window-Size

The size, in pixels, of the application window on the computer screen.

Gov-Vendor-License-IDs

A key-value pair of hashed license keys relating to the installation of the application. The developer has to provide or find a mechanism for accessing this.

Gov-Vendor-Product-Name

The application name, as marketed to users. It should be percent encoded. The developer has to provide or find a mechanism for accessing this.

Gov-Vendor-Version

A key-value structure listing the version(s) of the product involved in the request.

Comment: Some do appear to be complete madness, but ours is not to reason why, as someone once said.

The Header Helpers

The helpers, mainly contributed by Russell Weetch contain functions for collecting the various values required by the headers, like IPs and versions. There are currently 6 support units for this, 4 of which are devoted to getting values for headers (Systematic.AppVersion, Systematic.MacAddress, uSMBIOS and VAT.Headers.Utills).

This doc will not cover the individual methods used, but at least one requires the JCL to be installed. If this is not present, then that method can be commented out and an alternative method used.

The other 2 units (HmrcHeaders & Systematic.VAT.Headers) contain 2 different approaches to collecting the values and presenting them to the RestClients. Both of these include records to hold the multi-factor values, if present and show how to use the functions in the other units to collect the required information.

The demos that are available for testing, including Self Assessment and VAT all use the HmrcHeaders unit, but developers should look at and understand both approaches, before choosing either one of these or deciding to roll their own instead.

The values which have to be supplied by the application can be hard-coded or looked up when required, but it is down to the application developer to provide these values somehow.

The values that cannot be looked up currently are listed below:

- The product name, as opposed to the actual application name, if it is different.
- The Installation GUID
- The Installation License
- The Multi-factor type, timestamp and reference value.

In the demo apps, the main forms contain hard-coded values for the GUIDs and set all values in a header record in the FormCreate method. The LoadDetails method, which loads the client keys, also has the ability to replace the AppName and AppGuid values dynamically. In the demos these are just loaded from an ini file for convenience, but it demonstrates a way of handling the general process of setting these values.

The multi-factor seems to be based on the assumption that no application is dependent solely on user/password login any more. Where the application still works like that, which in reality is probably most of them, the header type should be set to "OTHER", with the values left blank. In theory HMRC need to be informed of this, so presumably are building a list of non-compliant apps. Whether this is something that will be required in future is currently unknown.

If setting values for the Multi-Factor header, then it needs some kind of value, as described in the HMRC headers page and a timestamp for the time the authorization was last successful. Applications using this kind of validation and now accessing the HMRC REST APIs should now

log both an appropriate value and the time of the last authorization and then provide mechanisms to access these values for the purpose of setting the headers.

Frameworks – VCL or FMX.

Some of the header units are, or use, FMX units. These have been tested in the VCL demos and have been found to work without any issues, although there may be a compiler warning. Similarly, the base rest client contains 1 compiler switch based on a conditional define of FMX, which should be set in FMX projects. This is because the authorisation form is framework specific. In testing, however, the FMX demo worked with the VCL form and the VCL demo worked with the FMX form, but to avoid compiler warnings and potential problems, the conditional define should be used in FMX projects.

Some Links

The API listing was here

<https://developer.service.hmrc.gov.uk/api-documentation/docs/api/>

The desktop fraud headers reasoning was here

<https://developer.service.hmrc.gov.uk/guides/fraud-prevention/#why-you-must-send-data>

The desktop fraud headers descriptions were here

<https://developer.service.hmrc.gov.uk/guides/fraud-prevention/connection-method/desktop-app-direct/>

The small print

Readers do so at their own risk. The author, other project contributors and the UKDG, its members and officials accept no liability for any inconvenience caused as result of reading this document, including, but not limited to, loss of or damage to equipment, reputation or revenue. The comments and views expressed in this document represent solely the transient opinions of the author and should in no way be considered as representing the views of other contributors to the project, members and officials of the UKDG or anyone else completely unconnected to any part of it.